

Résumé du guide GUOT / trust-api

Objectif

Ce guide explique comment intégrer la signature électronique GUOT dans une application métier comme SIFEC, avec un modèle à 3 couches : Layer 1 pour le payload métier, Layer 2 pour le PDF, et Layer 3 pour le cachet institutionnel.

Architecture

Pattern à 3 couches :

- Layer 1 : signature du payload métier (/sign)
- Layer 2 : signature documentaire du PDF (/sign-document)
- Layer 3 : cachet institutionnel (/seal-document)

Important : L2 et L3 se font ensemble sur le même hash PDF, dans la même transaction.

Prérequis

Variables d'environnement : PKI_TRUST_API_URL, PKI_API_KEY, PKI_CLIENT_CERT, PKI_CLIENT_KEY, PKI_CA_CERT. L'API key est obtenue via la console Signum après validation du tenant GUOT. Pas de GET /status avant chaque signature ; l'appel de signature est l'autorité.

Enrôlement PKI

Signataires humains : POST /v1/signers, stocker actor_id stable. Institution : institution_id fourni par GUOT/Signum. Ne pas créer le tenant en production. Statut d'acteur : contrôler ponctuellement, pas systématiquement avant chaque signature.

Modifications BD

Ajouter des colonnes PKI dans toutes les tables de documents officiels, notamment proof_id, payload_hash, actor_id, actor_nom, certificate_ref, signed_at, rfc3161_I1_serial, pdf_content_hash, doc_sig_id, doc_sig_signed_at, rfc3161_I2_serial, doc_seal_id, doc_seal_sealed_at, rfc3161_I3_serial, pdf_path, print_count, first_delivered_at. Ajouter des index pour proof_id, actor_id, doc_sig_id.

Layer 1

Construire un payload JSON canonique trié alphabétiquement, incluant actor_id, cert_fingerprint, document_id, document_type, transaction_id et les données métier essentielles. Appeler POST /sign avec transaction_id, actor_id, payload, purpose. Stocker proof_id, payload_hash, signed_at, rfc3161_I1_serial.

Layer 2

Générer le PDF sans cartouche. Calculer le hash SHA-256 du binaire PDF. Appeler POST /sign-document avec document_hash, actor_id, document_type, purpose. Stocker pdf_content_hash, doc_sig_id, doc_sig_signed_at, rfc3161_I2_serial.

Layer 3

Appeler POST /seal-document avec institution_id, document_hash, purpose, et optionnellement doc_sig_id. Stocker doc_seal_id, doc_seal_sealed_at, rfc3161_l3_serial. Générer le PDF final avec cartouche contenant proof_id, doc_sig_id, doc_seal_id, TSA serials, actor_nom, institution, date et lien de vérification.

MinIO

Migrer le stockage PDF du disque local vers MinIO S3 compatible. Configurer un disque Laravel minio et installer league/flysystem-aws-s3-v3. Migrer les fichiers existants via une commande Artisan puis basculer FILESYSTEM_DISK=minio.

Vérification

Vérification publique via portail Signum avec proof_id. Vérification interne via /verify et /verify-document. Vérification hors ligne possible avec OpenSSL et recalcul du hash du payload et du PDF.

Cycle de vie des certificats

Certificats GUOT valables 1 an. Renouveler à J-30. Statut suspended temporaire, révocation définitive nécessite un nouveau signer. Révocation urgente via POST /v1/signers/{actor_id}/revoke. Suspension tenant renvoie 403 sur les opérations de signature.

Checklist production

Tenant validé, clé API live configurée, MinIO accessible, mTLS installé si nécessaire, acteurs enrôlés, colonnes PKI ajoutées, QR codes de vérification dans les PDF, tests L1/L2/L3 réussis, téléchargement PDF depuis MinIO, vérification publique et hors ligne validée.